

W12D4 - Remediation

metasploitable - remediation

nessus scan

Danilo 'danix' Macrì - miamail@mio.sito

Scan started on 02/10/2025 - duration (days): 1

Contents

W12D4 - remediation per metasploitable	1
Scope	1
Vulnerabilità prese in considerazione	1
Mitigazione	2
backdoor shell sulla porta 1524	2
vnc password ' <i>password</i> '	4
l'intero filesystem è accessibile in scrittura tramite NFS	6
Alcune directory del webserver sono visibili	8
Server X11 in ascolto per connessioni TCP	10
Remote shell (rsh) in esecuzione	13

W12D4 - remediation per metasploitable

Oggi vedremo come rimediare ad alcune falle di sicurezza presenti sulla nostra macchina metasploitable.

Scope

Il target dei nostri test è la macchina metasploitable, raggiungibile nel nostro laboratorio all'indirizzo:

- 192.168.50.101
- http://metasploitable

Vulnerabilità prese in considerazione

Non abbiamo considerato tutte le vulnerabilità ma solo quelle in questa tabella:

Vulnerability Name	Severity	Σ
backdoor shell sulla porta 1524	Critical	1
vnc password 'password'	Critical	1
l'intero filesystem è accessibile in scrittura tramite NFS	Medium	1
Alcune directory del webserver sono visibili	Medium	1
Server X11 in ascolto per connessioni TCP	Low	1
Remote shell (rsh) in esecuzione	Info	1
Total Vulnerabilities Found		6

Mitigazione

backdoor shell sulla porta 1524

CVSS Vector	Score	Severity
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	9.8	Critical

Questa vulnerabilità conosciuta come ingreslock lascia aperta una root shell sulla porta 1524. Per trovare il servizio che la apre abbiamo usato il comando

```
$> sudo netstat -tunpl |grep 1524
```

Che ci ha restituito questo output:

```
msfadmin@metasploitable:~$ sudo netstat -tunpl |grep 1524
tcp        0      0 0.0.0.0:1524 0.0.0.0:*        LISTEN
4396/xinetd
msfadmin@metasploitable:~$
```

Permettendoci di capire che il servizio xinetd è responsabile dell'avvio della backdoor. Per trovare il file di configurazione abbiamo lanciato questo comando

```
$> sudo grep -lr "1524" /etc
```

E abbiamo così trovato il file /etc/inetd.conf in cui viene inizializzata la backdoor

```
msfadmin@metasploitable:~$ sudo grep -lr "1524" /etc
grep: /etc/alternatives/uncpasswd.1.gz: No such file or directory
/etc/services
grep: warning: /etc/tomcat5.5/tomcat5.5: recursive directory loop
/etc/inetd.conf
msfadmin@metasploitable:~$
```

Quindi siamo andati a modificare il file come segue:

```
#<off># netbios-ssn      stream  tcp      nowait  root    /usr/sbin/tcpd  /usr/sbin/smbd
telnet                  stream  tcp      nowait  telnetd /usr/sbin/tcpd  /usr/sbin/in.telnetd
#<off># ftp              stream  tcp      nowait  root    /usr/sbin/tcpd  /usr/sbin/in.ftpd
tftp                    dgram   udp      wait    nobody  /usr/sbin/tcpd  /usr/sbin/in.tftpd
pd /srv/tftp            stream  tcp      nowait  root    /usr/sbin/tcpd  /usr/sbin/in.rshd
login                   stream  tcp      nowait  root    /usr/sbin/tcpd  /usr/sbin/in.rlogind
gind                    stream  tcp      nowait  root    /usr/sbin/tcpd  /usr/sbin/in.rlogind
exec                    stream  tcp      nowait  root    /usr/sbin/tcpd  /usr/sbin/in.rexecd

# La linea in basso lancia la backdoor shell ingreslock tramite xinetd
# sulla porta 1524. Commento la linea per chiudere la vulnerabilita'
#
# ingreslock stream tcp nowait root /bin/bash bash -i
~
~
~
~
```

E riavviando il sistema vedremo che la porta risulterà chiusa.

```
(kali㉿kali)-[~]
$ nmap -sS -p 1524 metasploitable
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-02 10:59 EDT
Nmap scan report for metasploitable (192.168.50.101)
Host is up (0.00017s latency).

PORT      STATE SERVICE
1524/tcp  closed ingreslock
MAC Address: 08:00:27:B5:7A:73 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.14 seconds
```

vnc password 'password'

CVSS Vector	Score	Severity
CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C	10.0	Critical

Questa vulnerabilità è suscettibile ad attacchi brute force e viene individuata ed exploitata da nmap, il servizio VNC risulta accessibile tramite l'utilizzo di una password debole, in questo caso 'password'. Per mitigare il problema utilizzeremo il comando:

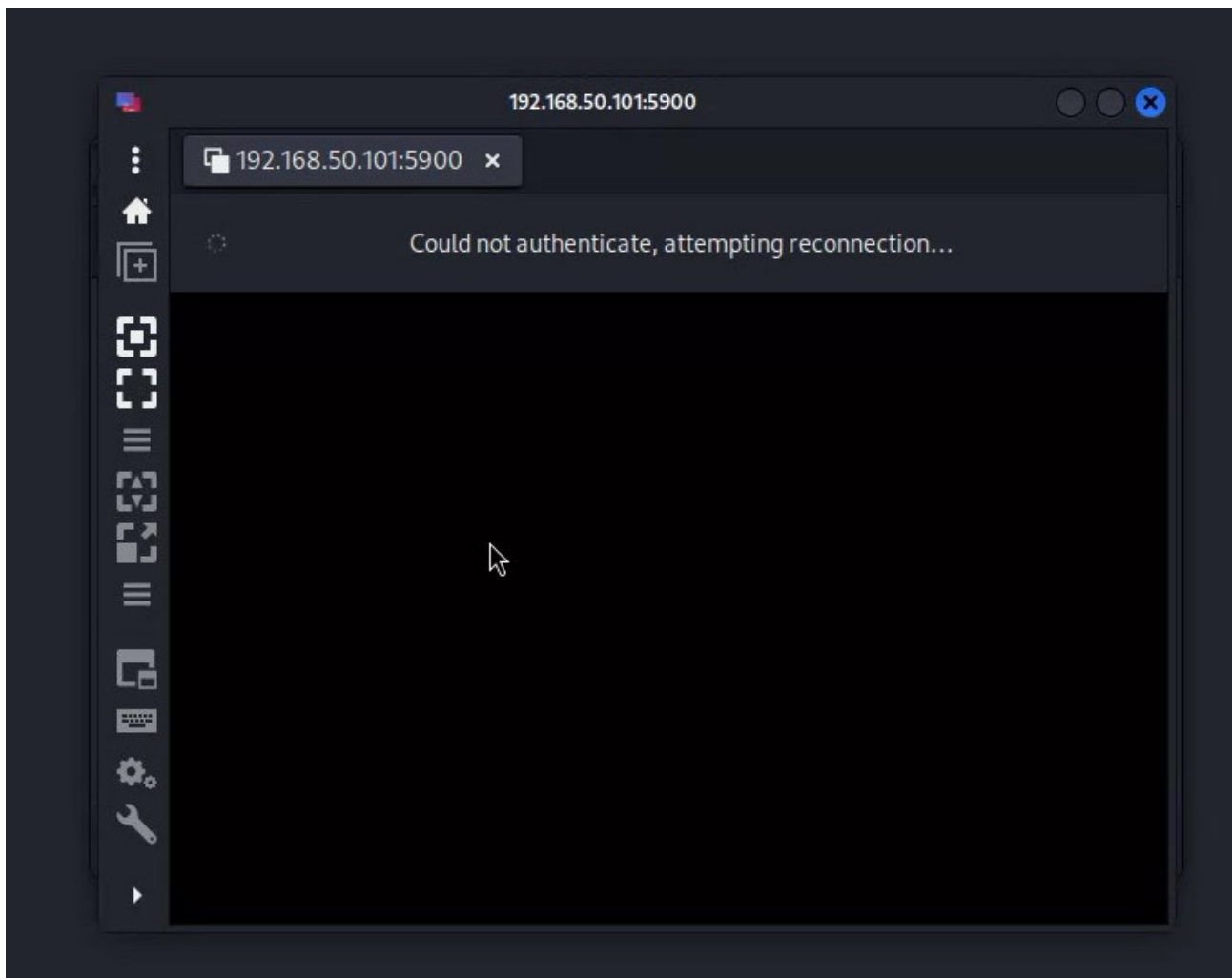
```
$> vncpasswd
```

per modificare la password con una più difficile da indovinare.

```
msfadmin@metasploitable:~$ sudo vncpasswd
Using password file /home/msfadmin/.vnc/passwd
Error: bad ownership on /home/msfadmin/.vnc
msfadmin@metasploitable:~$ sudo su
root@metasploitable:/home/msfadmin# cd
root@metasploitable:~# vncpasswd
Using password file /root/.vnc/passwd
Password:
Verify:
Would you like to enter a view-only password (y/n)? n
root@metasploitable:~# _
```

Come vediamo dallo screenshot, non basta dare il comando con sudo ma bisogna diventare root, in quanto il server VNC è avviato per l'utente root. In questo modo al riavvio del server la vulnerabilità sarà risolta.

Per testare la connessione utilizziamo Remmina e vediamo se la password viene accettata.



Come vediamo Remmina non riesce ad autenticarsi con la password *'password'*.

l'intero filesystem è accessibile in scrittura tramite NFS

CVSS Vector	Score	Severity
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	7.5	Medium

Vediamo adesso come mitigare la configurazione di un export attivo per il servizio NFS che permette a tutti di montare da remoto l'intero filesystem del nostro server con scrittura abilitata e possibilità di scalare i privilegi. Vediamo la situazione iniziale andando a leggere il file `/etc/exports` dove vengono definiti gli export di NFS, possiamo anche utilizzare il comando

```
$> exportfs -v
```

per visualizzare le stesse informazioni:

```
msfadmin@metasploitable:~$ less /etc/exports
# /etc/exports: the access control list for filesystems which may be exported
# to NFS clients. See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes hostname1(rw,sync) hostname2(ro,sync)
#
# Example for NFSv4:
# /srv/nfs4 gss/krb5i(rw,sync,fsid=0,crossmnt)
# /srv/nfs4/homes gss/krb5i(rw,sync)
#
/*(rw,sync,no_root_squash,no_subtree_check)
msfadmin@metasploitable:~$ exportfs -v
/*(rw,sync,no_root_squash,no_subtree_check)
msfadmin@metasploitable:~$ _
```

Si può vedere come l'intero filesystem a partire dalla root / sia leggibile e scrivibile a tutti.

Per porre rimedio alla vulnerabilità andremo a creare una directory utilizzata solo per la condivisione di files, nella home dell'utente con il seguente comando:

```
$> mkdir /home/msfadmin/public
```

e poi, modificheremo il file `/etc/exports` come segue:

```
# /etc/exports: the access control list for filesystems which may be exported
#               to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes      hostname1(rw, sync) hostname2(ro, sync)
#
# Example for NFSv4:
# /srv/nfs4       gss/krb5i(rw, sync, fsid=0, crossmnt)
# /srv/nfs4/homes gss/krb5i(rw, sync)
#
# condivido solo la cartella "public" creata apposta nella home dell'utente
# per la condivisione pubblica di files. Autorizzo inoltre l'accesso solo
# sulla rete locale, e impedisco all'utente root di scalare i permessi.
/home/msfadmin/public 192.168.50.0/24(rw, sync, root_squash, no_subtree_check)
~
~
~
~
~
~
~
~
```

Adesso la condivisione tramite NFS è impostata come segue:

- solo la directory /home/msfadmin/public è condivisa
 - è possibile accedere solo tramite la sottorete 192.168.50.0/24
 - è possibile montare la cartella in lettura e scrittura (opzione rw)
 - non è possibile scalare i permessi di root (opzione root_squash)

Per riavviare gli export di NFS bisognerà dare il comando

```
$> exportfs -a
```

E successivamente per verificare l'effetto della nostra mitigazione potremo dare di nuovo il comando con l'opzione -v e verificare che sia tutto a posto.

Questo è quello che vediamo dalla nostra kali

```
(kali@kali)-[~]
$ showmount -e metasploitable
Export list for metasploitable:
/home/msfadmin/public 192.168.50.0/24
```


Alcune directory del webserver sono visibili

CVSS Vector	Score	Severity
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	5.3	Medium

Questa vulnerabilità è dovuta ad una incorretta configurazione del web server Apache, grazie alla quale alcune cartelle sono visibili e navigabili dal web in quanto non contengono un file di indice (index.php, o index.html ecc.) e potrebbero potenzialmente contenere dati sensibili, configurazioni o file di sistema.

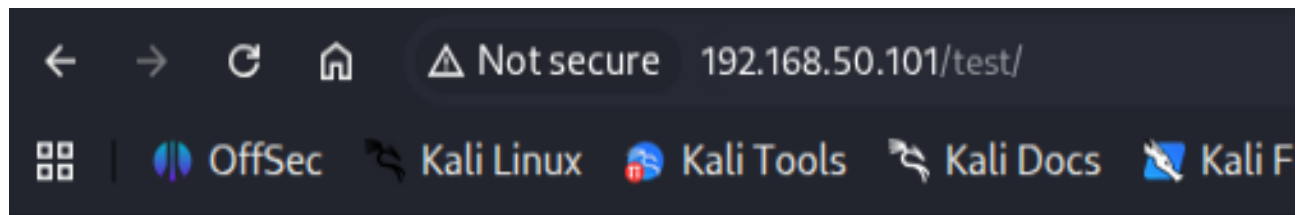
Le cartelle esposte sono le seguenti

- <http://192.168.50.101/dav/>
- <http://192.168.50.101/dav/QekLxm79.htm/>
- <http://192.168.50.101/dvwa/dvwa/>
- <http://192.168.50.101/dvwa/dvwa/css/>
- <http://192.168.50.101/dvwa/dvwa/images/>
- <http://192.168.50.101/dvwa/dvwa/includes/>
- <http://192.168.50.101/dvwa/dvwa/includes/DBMS/>
- <http://192.168.50.101/dvwa/dvwa/js/>
- <http://192.168.50.101/mutillidae/documentation/>
- <http://192.168.50.101/mutillidae/styles/>
- <http://192.168.50.101/mutillidae/styles/ddsmoothmenu/>
- <http://192.168.50.101/test/>
- <http://192.168.50.101/test/testoutput/>

Per bloccare il "*directory listing*", dovremo andare a disabilitare il relativo modulo di apache e ricaricare la configurazione con i seguenti comandi:

```
$> sudo a2dismod autoindex  
$> sudo /etc/init.d/apache2 force-reload
```

Il primo comando disabilita il modulo e il secondo forza apache2 a ricaricare la configurazione. Adesso andando a visitare uno dei link dalla lista qui sopra vedremo che apache ci risponderà che non è disponibile.



Not Found

The requested URL /test/ was not found on this server.

Apache/2.2.8 (Ubuntu) DAV/2 Server at 192.168.50.101 Port 80

Server X11 in ascolto per connessioni TCP

CVSS Vector	Score	Severity
CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N	2.6	Low

E' stato rilevato il server grafico X11 in ascolto per connessioni TCP sulla porta 6000, questa vulnerabilità è dovuta al fatto che il server X11 trasmette le informazioni in chiaro, quindi un soggetto attaccante potrebbe carpire informazioni in transito tra server e client.

Andiamo a verificare come viene avviato il server con il nostro solito comando netstat

```
$> sudo netstat -tunlp |grep 6000
```

```
msfadmin@metasploitable:~$ sudo netstat -tunlp |grep 6000
[sudo] password for msfadmin:
tcp        0      0 0.0.0.0:6000          0.0.0.0:*            LISTEN
4562/Xtightvnc
msfadmin@metasploitable:~$ _
```

e vediamo che il comando che lo esegue è Xtightvnc, cerchiamo quindi la stringa **vnc** nella directory /etc e troviamo un paio di righe interessanti:

```
$> grep -irl "vnc" /etc
```

```
root@metasploitable:~# grep -irl vnc /etc/
/etc/mysql/client-key.pem
/etc/alternatives/www-browser
/etc/alternatives/vncconnect
/etc/alternatives/vncserver
/etc/alternatives/vncpasswd
grep: /etc/alternatives/vncpasswd.1.gz: No such file or directory
/etc/alternatives/Xvnc.1.gz
/etc/alternatives/vncconnect.1.gz
/etc/alternatives/Xvnc
/etc/alternatives/vncserver.1.gz
/etc/apparmor/severity.db
/etc/bash_completion
grep: warning: /etc/tomcat5.5/tomcat5.5: recursive directory loop
/etc/rc.local
/etc/unreal/curl-ca-bundle.crt
root@metasploitable:~# _
```

Vediamo che una delle alternative installate da debian è vncserver, e inoltre vediamo il file /etc/rc.local che viene usato di solito sui sistemi GNU/Linux per avviare programmi personalizzati o che non hanno uno script di avvio.

un cat del file /etc/rc.local ci mostra che il server VNC viene avviato da li

```
root@metasploitable:~# cat /etc/rc.local
#!/bin/sh -e
#
# rc.local
#
# This script is executed at the end of each multiuser runlevel.
# Make sure that the script will "exit 0" on success or any other
# value on error.
#
# In order to enable or disable this script just change the execution
# bits.
#
# By default this script does nothing.

nohup /usr/bin/rmiregistry >/dev/null 2>&1 &
nohup /usr/bin/unrealircd &
rm -f /root/.vnc/*.pid
HOME=/root LOGNAME=root USER=root nohup /usr/bin/vncserver :0 >/root/.vnc.log 2>&
1 &
nohup /usr/sbin/druby_timeserver.rb &

exit 0
root@metasploitable:~#
```

scopriamo inoltre che l'intero server X viene avviato come root.

Andiamo a verificare il log dove viene indirizzato l'output di vncserver e vediamo come viene avviato il programma.

```
root@metasploitable:~# less vnc.log

New 'X' desktop is metasploitable:0

Starting applications specified in /root/.vnc/xstartup
Log file is /root/.vnc/metasploitable:0.log

root@metasploitable:~#
```

Adesso sappiamo che lo script esegue tutto quello che c'è scritto nel file /root/.vnc/xstartup. Quindi andiamo a vedere se può tornarci utile questo file.

```
root@metasploitable:~# less .vnc/xstartup
#!/bin/sh

xrdb $HOME/.Xresources
xsetroot -solid grey
x-terminal-emulator -geometry 80x24+10+10 -ls -title "$VNCDESKTOP Desktop" &
xhosts + &
fluxbox
root@metasploitable:~# _
```

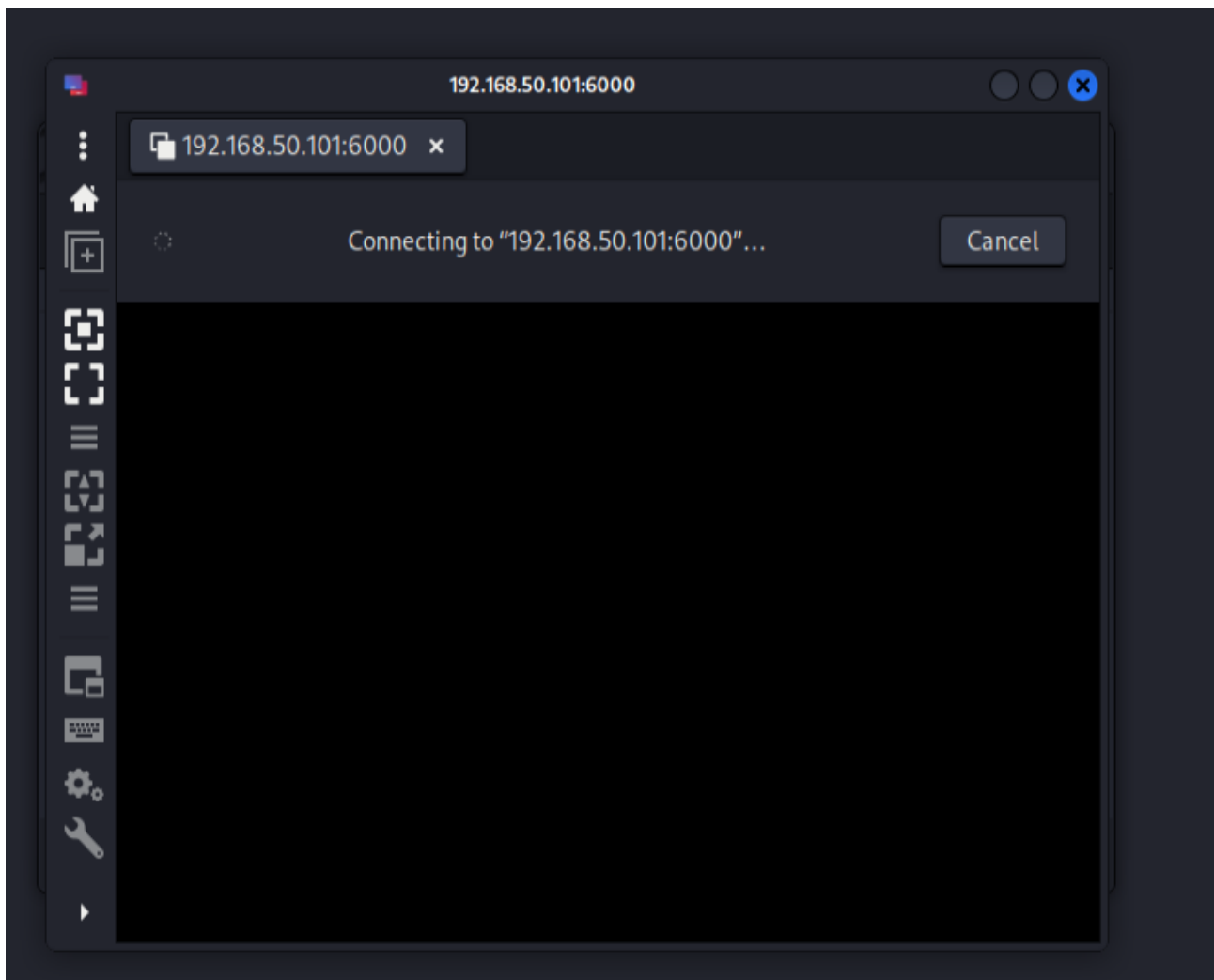
vediamo che uno dei comandi è

```
xhosts + &
```

Questo comando permette a tutti di connettersi al server X, ma possiamo modificarlo in:

```
xhosts +local &
```

In modo da permettere la connessione al server X solo dalla propria macchina, e rifiutare quindi connessioni dall'esterno. Questo bloccherà l'accesso alla porta 6000 anche se probabilmente risulterà ancora aperta.



Come possiamo vedere Remmina non riesce ad aprire una connessione sulla porta 6000.

Remote shell (rsh) in esecuzione

I servizi rsh, rexec e rlogin sono dei servizi di shell remota sviluppati dall'università di Berkley negli anni '80 e sono considerati oggi giorno **insicuri per design**.

Andremo a bloccarli a livello di firewall utilizzando ufw (uncomplicated firewall), pacchetto già presente sulla nostra metasploitable ma disabilitato di default.

Per prima cosa abilitiamo il servizio così che venga lanciato al riavvio della macchina.

```
$> sudo ufw enable
```

```
msfadmin@metasploitable:~$ sudo ufw enable
Firewall started and enabled on system startup
msfadmin@metasploitable:~$
```

In questo stato il firewall bloccherà tutto il traffico in entrata, quindi per permettere il traffico in ingresso andremo a definire la policy di default come **"ALLOW"** col seguente comando:

```
$> sudo ufw default ALLOW
```

e poi procederemo a inserire delle regole per bloccare le porte per i servizi di shell remota

```
$> sudo ufw deny 512/tcp
$> sudo ufw deny 513/tcp
$> sudo ufw deny 514/tcp
```

Per verificare che le regole siano state inserite lanceremo il comando

```
$> sudo ufw status numbered
```

```
msfadmin@metasploitable:~$ sudo ufw deny 512/tcp
Rule added
msfadmin@metasploitable:~$ sudo ufw deny 513/tcp
Rule added
msfadmin@metasploitable:~$ sudo ufw deny 514/tcp
Rule added
msfadmin@metasploitable:~$ sudo ufw status numbered
Firewall loaded
```

To	Action	From
512:tcp	DENY	Anywhere
513:tcp	DENY	Anywhere
514:tcp	DENY	Anywhere

```
msfadmin@metasploitable:~$ _
```

E da kali possiamo testare con nmap e vedere se le porte vengono filtrate

```
(kali㉿kali)-[~]
└─$ nmap -sS -p 512-514 metasploitable
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-02 11:08 EDT
Nmap scan report for metasploitable (192.168.50.101)
Host is up (0.00015s latency).

PORT      STATE      SERVICE
512/tcp   filtered  exec
513/tcp   filtered  login
514/tcp   filtered  shell
MAC Address: 08:00:27:B5:7A:73 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.36 seconds
```

Con questo si conclude la nostra mitigazione delle vulnerabilità selezionate sulla nostra metasploitable

Alla prossima.

